

AI-Assisted Development Transparency Disclosure

Tools Used

Tool	Purpose	Where Used	Why Used	Dev-time vs Runtime	Acceptance
Google Antigravity IDE (Gemini)	Code generation, security analysis guidance, documentation	Throughout the project	Accelerate development, ensure comprehensive coverage	Development-time	Modified — all code reviewed, tested, and adapted
Google Gemini 3.6 Flash API	Patient symptom triage assistant	Runtime — /api/ai/symptom-check endpoint	Provide AI-powered health assessment for patients	Runtime	Accepted with security boundaries
Semgrep 1.136.0	Static Application Security Testing	Backend source code scanning	Identify code-level vulnerabilities	Development-time	Findings manually validated
gitleaks 8.30.1	Secret scanning	Git history analysis	Detect hardcoded credentials	Development-time	Results accepted (0 findings)
Burp Suite Community Edition	Dynamic Application Security Testing	Manual penetration testing	Validate IDOR, privilege escalation, auth flaws	Development-time	All findings manually validated with PoCs

AI Used to Build vs AI Running Inside

AI Used During Development (Development-Time)

- **Google Antigravity IDE:** Used for code generation, security analysis, vulnerability research, and documentation creation
- **All generated code was reviewed, tested, and modified** before acceptance
- **All security findings were manually validated** using Burp Suite before being included in the report

AI Running Inside the Application (Runtime)

- **Google Gemini 3.6 Flash:** Powers the patient symptom triage assistant
- **Security boundaries enforced:**
 - AI cannot access the database directly
 - AI cannot access internal APIs or secrets
 - All AI requests go through backend authorization (patient-only)
 - Input sanitized for prompt injection patterns
 - Output validated and structured before returning to user
 - All AI activity logged (without storing PHI in logs)
 - AI assessment is clearly labeled as "NOT a medical diagnosis"

Validation of AI-Generated Findings

- Every vulnerability finding was manually validated through Burp Suite Repeater
- Before/after screenshots captured for all remediated findings
- No finding was included based solely on AI suggestion without manual proof